

BUSINESS INFORMATION SYSTEMS

Professor : Rejaul Chowdhury

Email: chowdhr@algonquincollege.com

Office: T323

Objectives

- Assess different types of risks for information systems design.
- Describe risk management processes.
- Describe risk management steps.
- Manage business risks through insurance.
- Discuss special forms of insurance for business.
- Mitigate risks with operational controls.
- Mitigate risks with technical controls.
- Assess the risk of Cybercrime as part of Information Systems Design.
- Discuss Cyber security strategy for Businesses.



Risk Assessment for Information Systems Design

A **risk assessment** essentially consists of:

- Clearly identifying organizational information assets, the data and information systems on which the organization depends.
- Understanding vulnerabilities, the susceptibility of the asset to breakdown or malicious attack, associated with identified assets.
- Identifying threats, object, person or incident capable of exploiting identified vulnerabilities.



Risk Assessment for Information Systems Design

- Human Threat: The most complicated in that the category includes such a wide variety of behaviors.
 - Accidental behavior by organizational members
 - Accidental behavior by technical support personnel
 - Accidental behavior by organizational clients and other individuals that have authorized access to the information or information service
 - Malicious behavior by organizational insider
 - Malicious behavior by organizational outsider (malicious behaviors can be further broken out to include: theft, sabotage, extortion).



Risk Assessment for Information Systems Design

- Natural: Flood, fire, tornado, ice storm, earthquake, flu pandemic
- Environmental: Utility failure, chemical spill, gas line explosion.
- Technical: Hardware or software failure (whether maliciously intended or through normal wear and tear), perimeter defense failures (faulty closed circuit TV, key-code access system, fire alarm)
- Operational: A faulty process that unintentionally compromises information confidentiality, integrity or availability. An operational procedure that allows application programmers to upgrade software programs without testing or notifying system operators may result in prolonged outages.



Coping with Risk (1 of 2)

- **Risk**
 - uncertainty about future events
- **Speculative Risk**
 - risk involving the possibility of gain or loss
- **Pure Risk**
 - risk involving only the possibility of loss or no loss



Coping with Risk (2 of 2)

- **Risk Management**
 - process of conserving the firm's earning power and assets by reducing the threat of losses as a result of uncontrollable events



Risk-Management Process (1 of 3)

1. Identify Risks and Potential Losses

- managers analyze a firm's risks to identify potential losses

2. Measure the Frequency and Severity of Losses and Their Impact

- managers must consider both history and current activities



Risk-Management Process (2 of 3)

3. Evaluate Alternatives and Choose the Techniques that Will Best Handle the Losses

- managers decide how to handle risk
 1. risk avoidance
 2. risk control
 3. risk retention
 4. risk transfer



Risk-Management Process (3 of 3)

4. Implement the Risk-Management Program

- Implementing risk-management decisions depends on both the technique chosen and the activity being managed

5. Monitor Results

- managers must continuously monitor a company's risks, re-evaluate the methods used for handling them, and revise them as necessary



Risk Management Steps

- **Develop a risk management plan**
 - Review of the project's scope, stakeholders, budget, schedule, and any other internal or external factors that might affect the project
 - Define project roles and responsibilities, risk management methods and procedures, categories of risks, and contingency plans



Risk Management Steps

- **Identify the risks**
 - List each risk and assesses the likelihood that it could affect the project
- **Analyze the risks**
 - This typically is a two-step process
 - Qualitative risk analysis evaluates each risk by estimating the probability that it will occur and the degree of impact
 - Quantitative risk analysis is to understand the actual impact in terms of dollars, time, project scope, or quality



Risk Management (Cont.)

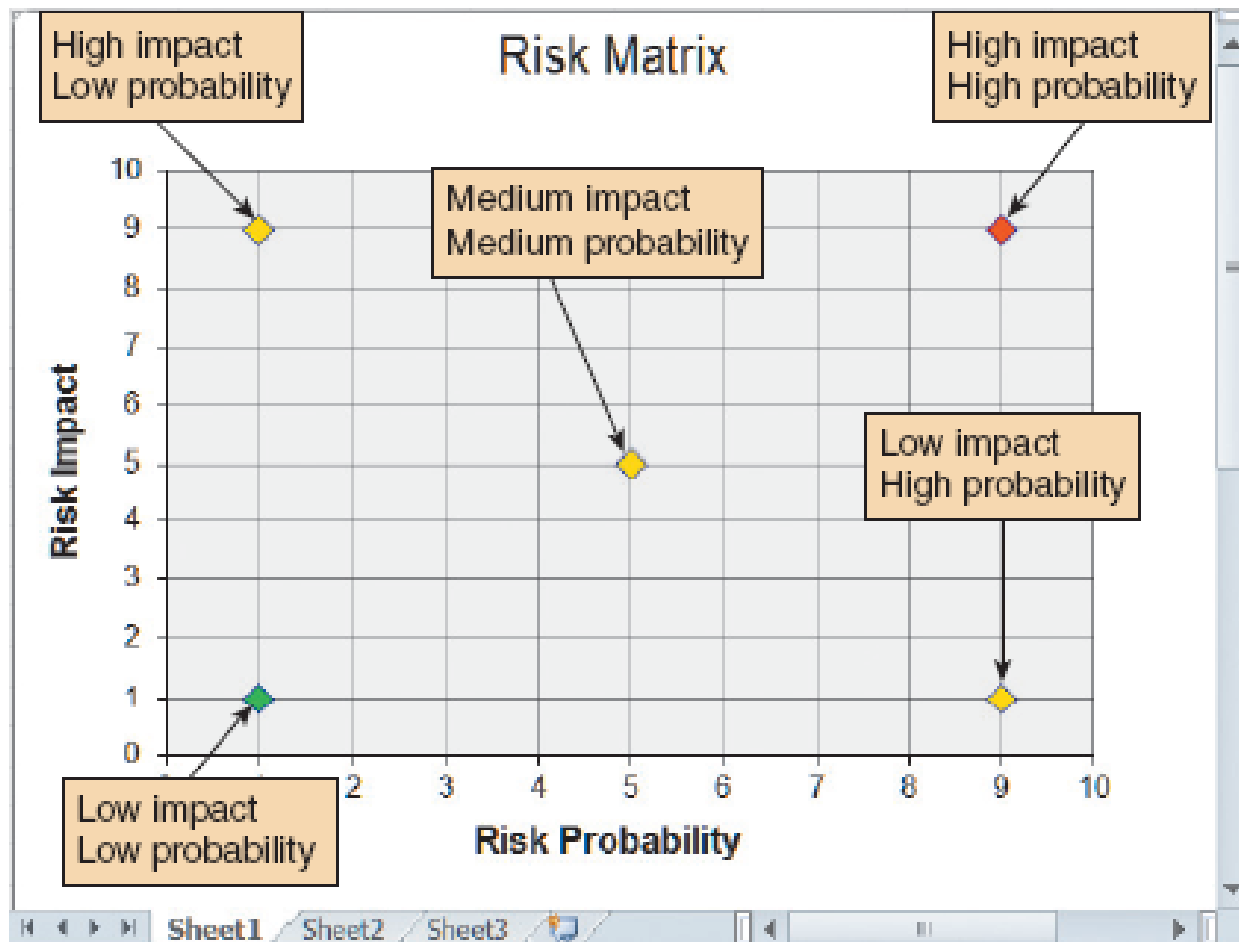


FIGURE a risk matrix that shows risk probability and potential impact.



Risk Management Software

- Assigns specific dates as constraints
- Aligns task dependencies
- Notes external factors that might affect a task
- Tracks progress
- Displays tasks that are behind schedule
- Links risks with specific tasks and projects
- Specifies probability and impact
- Assigns ownership
- Tracks progress to manage projects more efficiently



Insurance as Risk Management

- **Insurance Premium**
 - fee paid to an insurance company by a policyholder for insurance coverage
- **Insurance Policy**
 - formal agreement to pay the policyholder a specified amount in the event of certain losses
- **Deductible**
 - amount of the loss that the insured must absorb before reimbursement is made



Insurable Versus Uninsurable Risks

- An insurable risk must meet the following four criteria:
 1. Predictability
 2. Casualty
 3. Un-connectedness
 4. Verifiability



Special Forms of Insurance for Business

(1 of 3)

- **Liability Insurance**
 - insurance covering losses resulting from damage to people or property when the insured party is judged liable
- **Workers' Compensation Coverage**
 - coverage provided by a firm to employees for medical expenses, loss of wages, and rehabilitation costs resulting from job-related injuries or disease



Special Forms of Insurance for Business

(2 of 3)

- **Property Insurance**
 - insurance covering losses resulting from physical damage to or loss of the insured's real estate or personal property
- **Business Interruption Insurance**
 - insurance covering income lost during times when a company is unable to conduct business



Special Forms of Insurance for Business

UNCLASSIFIED - NON CLASSIFIÉ

(3 of 3)

- **Key Person Insurance**
 - special form of business insurance designed to offset expenses entailed by the loss of key employees
- **Business Continuation Agreement**
 - special form of business insurance whereby owners arrange to buy the interests of deceased associates from their heirs



Mitigating Risks with Operational Controls

Three operational controls commonly associated with maintaining system availability are:

- System monitoring and incident response
- Performing system backups
- Planning for disaster recovery



System Monitoring and Incident Response

- **Incidents**
 - defined as any event that impacts the confidentiality, integrity or availability of an IT-enabled information service.
- **System monitoring**
 - Detecting incidents
- **Operations Control Center**
 - Used for system monitoring and incident management.
- **Help desk**
 - Used for providing user assistance.



Proactive System Monitoring vs Reactive System Monitoring

- Proactive monitoring
 - watching for indications that a failure may occur.
- Reactive monitoring
 - attempting to detect incidents as soon as possible after they occur and then respond to them.



System Backups

- Saving a copy of data stored on the system's hard drives to a different data storage facility.
- There are two major types of system backups
 - ❑ **Full system backups**
 - all the software and data residing on the system
 - ❑ **Incremental system backups**
 - only the data that has changed since the last full backup or last incremental backup



Disaster Recovery Plan

- Intended to provide detailed guidance concerning the actions to be taken in the event of following disaster:
 - Natural disasters, such as flood, earthquake or hurricane.
 - A major industrial accident.
 - The chance of intentional sabotage.
- IT considerations must be fully integrated into an organization's overall disaster recovery plan



Mitigating risks with technical controls

- The reliability of organizational IT-enabled information services includes
 - Redundant critical components (equipment, communications, etc.)
 - Power conditioning and backup power
 - System backup capabilities
 - Network and system monitoring tools



Business Continuity Plan

- Concerned with ensuring that essential organizational functions can continue to be performed in the event of any circumstance that massively disrupts the normal operations of an organization.
- To the extent an organization depends upon IT services to support core functions, then an effective business continuity plan necessarily ensures provision are made for restoration of essential IT services.

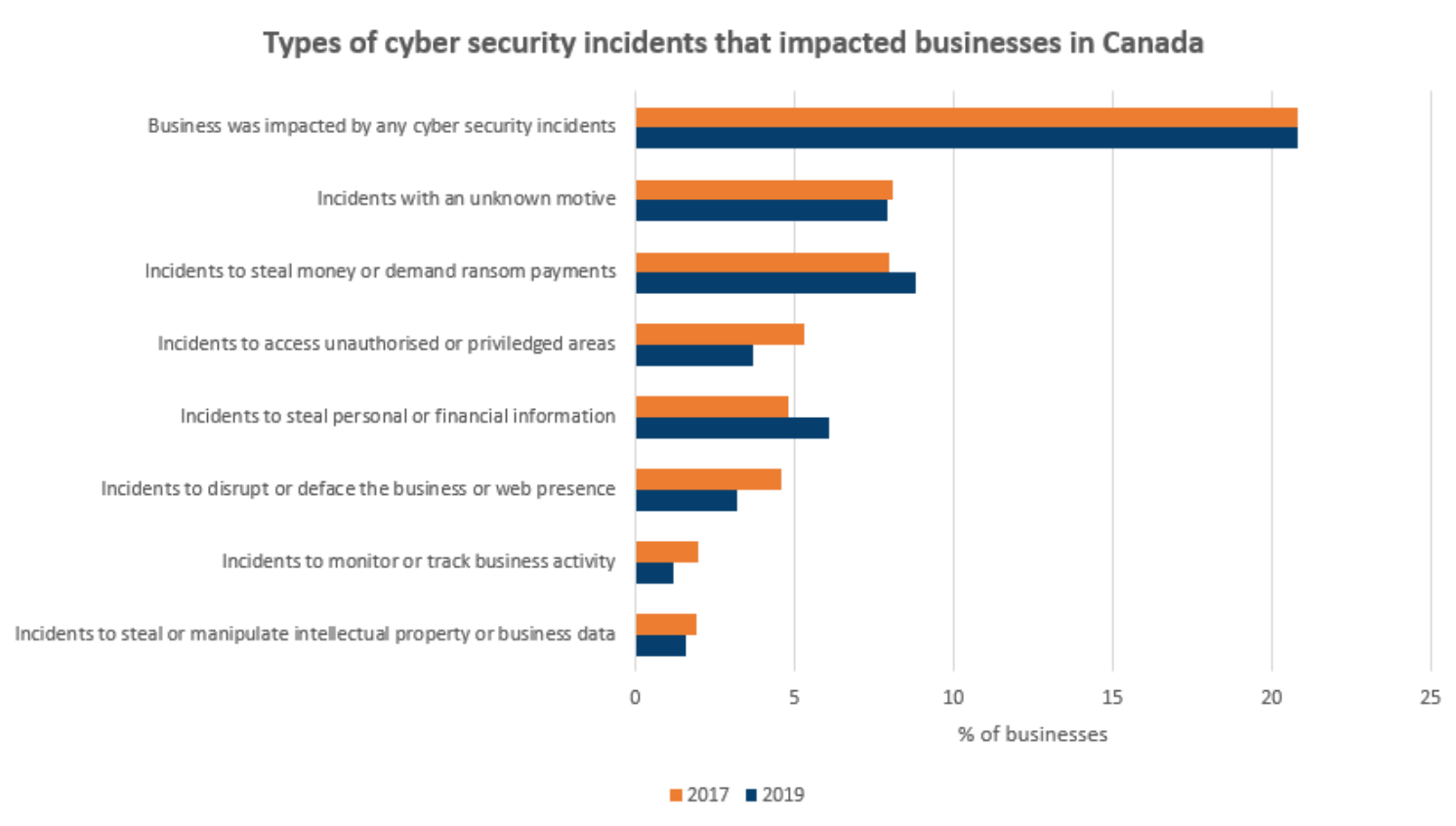


Assessing the risk of Cybercrime as part of Information Systems Design

- Cybercrime (also referred to as computer crime) is an illegal activity that is committed with the use of a computer, or where a computer is the object of the crime.
- Canadian businesses are targeted by cyber threat actors for their data about customers, partners and suppliers, financial information and payment systems, and proprietary information.



Statistics on Cyber Security Incidents



Types of Cybercrime

- Technology as Target of Crime
 - Malware
 - Denial-of-service (DoS)
- Technology Used to Commit Crime
 - Identity theft
 - Social engineering
 - Hacking
 - Phishing
 - Spoofing
 - Piracy



Technology as Target of Crime

-Malware

- Viruses and worms
 - Codes that replicate to destroy data. A virus requires a host in order to spread, such as an executable file, where a worm can spread unaided.
- Spyware
 - Software that gathers data, usually personal, about you and sends it without your knowledge.
- Ransomware
 - Malware that infects a computer and encrypts the data and requires payment (ransom) of the owner in order to access it again.



Technology as Target of Crime

-Denial-of-service (DoS)

- Prevents a web server from servicing authorized users.
- Example of DoS
 - Consider the following scenario. Dozens of computers are whirring away at an online bookmaker in the offshore gambling haven of Costa Rica. Suddenly a mass of blank incoming messages floods the company's computers, slowing operations to a trickle. No legitimate customers can get through to place their bets. A few hours later, the owner gets an e-mail that reads, "If you want your computers to stay up and running through the football season, wire \$40,000 to each of 10 numbered bank accounts in Eastern Europe."



Technology Used to Commit Crime

- Identity theft
 - when a criminal gains access to your personal information and uses it without your knowledge.
- Social engineering
 - when criminals lure individuals into sending them personal, confidential data that can be used in crime. For example, someone phones you posing as a customer service representative asking for your banking log-on information.
- Hacking
 - when someone accesses a computer without permission.



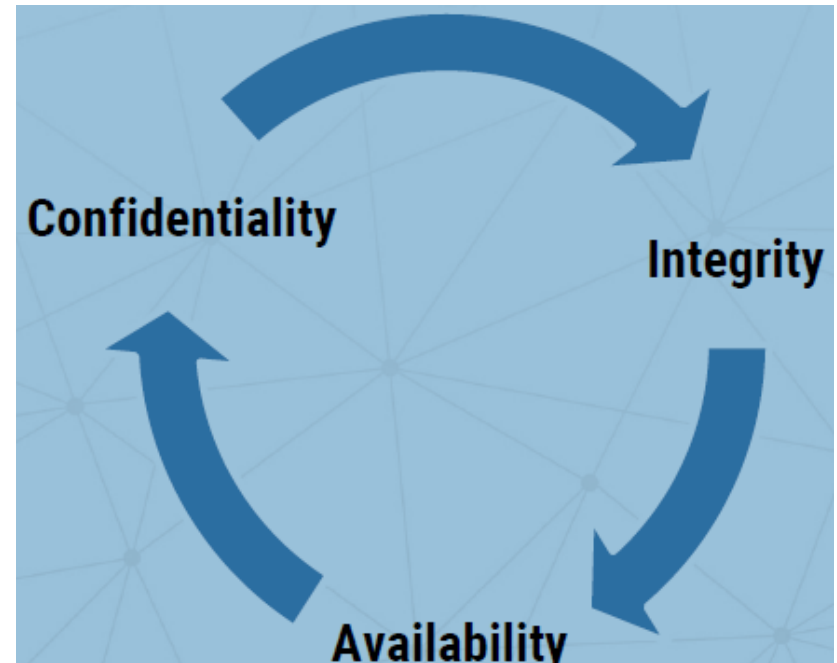
Technology Used to Commit Crime

- Phishing
 - When a user receives an e-mail that looks as if it is from a trusted source, such as their bank or employer. In the e-mail the user is asked to click a link and log in to a website that mimics the genuine website, then enter their ID and password. The userID and password are then captured by the attacker.
- Social engineering
 - A technique where culprits disguise their identities by modifying the address of the computer from which the scheme has been launched. Typically, the point is to make it look as if an incoming message has originated from an authorized source. Then, once the site's been accessed, the perpetrator can commit fraud, spy, or destroy data.
- Piracy
 - Illegal copying and distribution or use of software.



Cyber Security Goals

- To protect and maintain information and infrastructure in support of business requirements, the main cyber security goals include:
 - confidentiality
 - integrity
 - availability
- Additional goals include:
 - assurance
 - authenticity
 - non-repudiation



Secure Software Development Lifecycle (Secure SDLC)

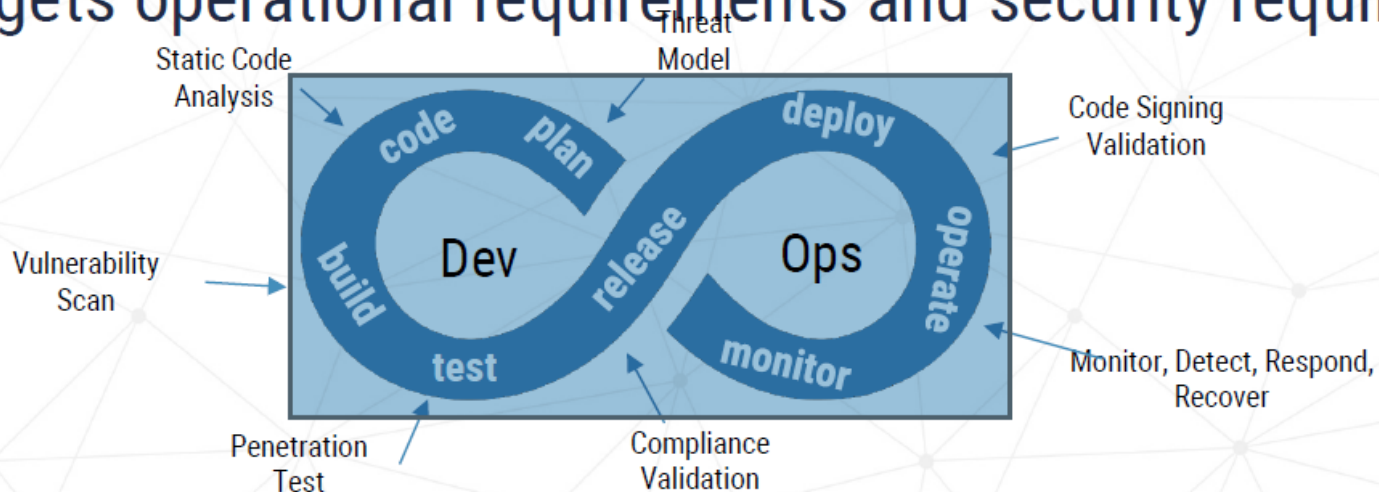
- A secure SDLC is a software development practice that integrates security requirements with business requirements
- Security requirements consider the sensitivity of the information system and the environment where it operates
- In a secure SDLC approach, testing evaluates operational requirements and security requirements
- A cross-functional development team using a secure SDLC will include security experts



DevSecOps Approach

- DevSecOps is a secure SDLC approach that combines development, security, and operations

DevSecOps operates using Test-driven Development (TDD), where testing targets operational requirements and security requirements



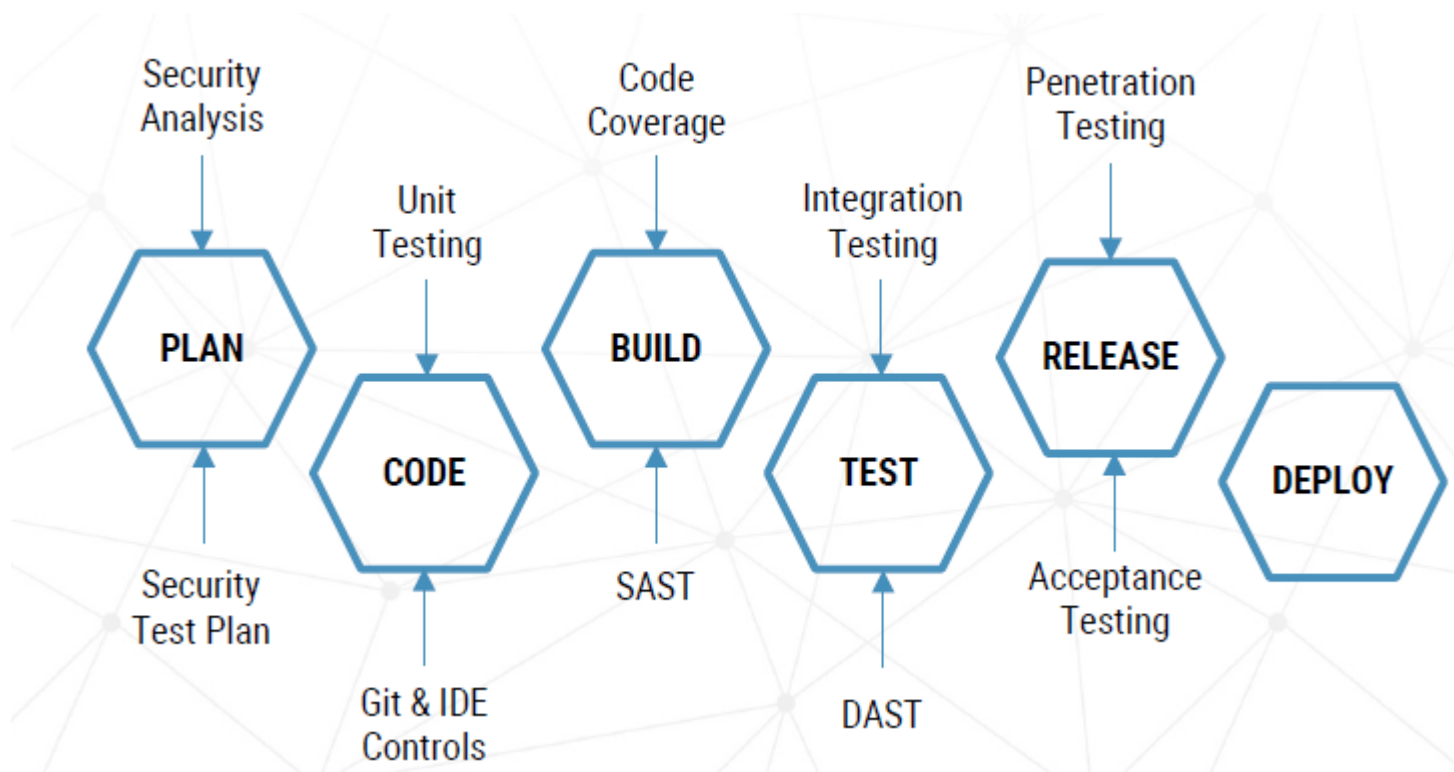
System Resilience

- No system is invulnerable to attack, unless the system is completely unusable
- In a secure SDLC approach, security must be maintained throughout the existence of the system
- Security is maintained by:
 - regular vulnerability scans
 - agile maintenance and updates
 - diligent monitoring
 - efficient incident response



Security Implementation Strategy

- A secure SDLC integrates security activities in the development pipeline



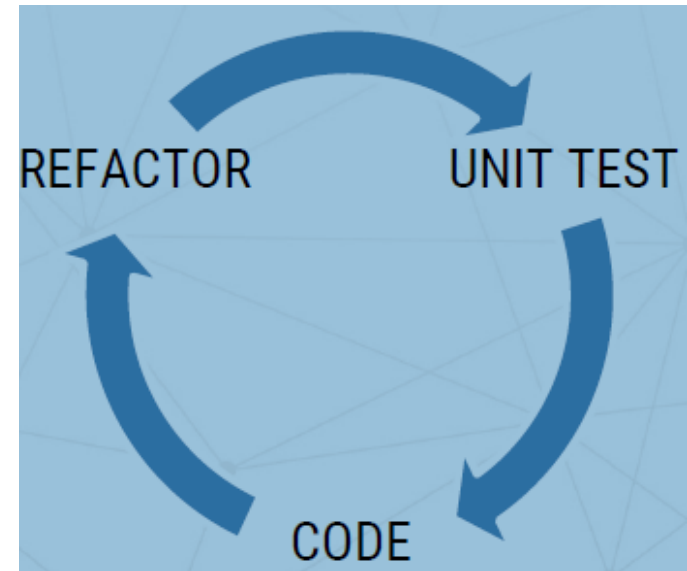
Test-Driven Development (TDD) Practice

- TDD is a development practice that focuses on unit testing
- Unit test cases are developed before creating the actual code
- The process is incremental, involving:
 - unit tests that target a specific functionality are built
 - software developed in order to pass the tests
 - software refactored
- Unit tests will accumulate and can validate the modified software before a release



Test-Driven Development (TDD) Practice

- TDD is a development practice that focuses on unit testing
- Unit test cases are developed before creating the actual code
- The process is incremental, involving:
 - unit tests that target a specific functionality are built
 - software developed in order to pass the tests
 - software refactored
- Unit tests will accumulate and can validate the modified software before a release



Unit Testing

- Unit testing applies to the smallest pieces of code that can be logically isolated in a system
- A unit test is meant to be:
 - very fast to execute
 - not dependent on external systems
- A unit test can be described as:
 - an executable specification
 - a code-defined requirement



Functional Testing

- A type of “black-box” testing and a process of quality assurance
- Functional testing is conducted to evaluate the compliance of a system or component with specified functional requirements
- Functional testing usually describes what the system does; it does not require an understanding of the inner workings of the software
- Testers are not programmers but closer to end users



Regression Testing

- A type of functional testing to verify that changes to the software have not introduced issues
- Automated regression testing can be implemented to prevent the reoccurrence of corrected bugs



Software Composition Analysis (SCA)

- No software is built in isolation today, they all have dependencies
- For a lot of software, a significant portion of their codebase comes from open sources
- Keeping track of known vulnerabilities in third-party libraries can be a challenge
- SCA runs vulnerability checks on third-party software to identify known vulnerabilities present in the code



Static Application Security Testing (SAST)

- Also known as source code analysis
- Conducted on scripted or compiled code
- Usually carried out as part of a code review, at the implementation phase of a lifecycle
- Uses tools to try to detect possible vulnerabilities within “static” source code by using techniques such as:
 - taint analysis
 - data flow analysis



Dynamic Application Security Testing (DAST)

- In dynamic testing, the application runs in a sandboxed environment and the scanner tests the running application
- It looks for security vulnerabilities such as XSS, SQL injection, command injection, path traversal, and insecure configurations
- There are many commercial and open source DAST tools available



Penetration Testing

- Penetration testers are also known as:
 - pen-testers
 - white hat hackers
 - ethical hackers
- They simulate an attack against a system within specific boundaries, with full authorization
- They use the same tools, tactics, and procedures as black hats to uncover weaknesses and vulnerabilities in the system



Business Logic

- Ensure that a verified application satisfies the following high-level requirements:
 - The business logic flow is sequential, processed in order, and cannot be bypassed
 - Business logic includes limits to detect and prevent automated attacks, such as continuous small funds transfers, or adding a million friends one at a time, and so on
 - High value business logic flows have considered abuse cases and malicious actors, and have protections against spoofing, tampering, information disclosure, and elevation of privilege attacks



Secure Deployment and Maintenance

- One of the final stages in delivering secure software is ensuring the security and integrity of developed applications are not compromised during deployment
- 3 levels of maturity are recognized:
 - Level 1: Deployment processes are fully documented
 - Level 2: Deployment processes include security verification milestones
 - Level 3: Deployment process is fully automated and incorporates automated verification of all critical milestones



Clean and Maintainable Code

- Complexity is the enemy of security
- Code should be developed in line with good practice, so it can be extended and maintained effectively
- Clean, well documented code is more efficient and easier to develop and secure
- Third-party code libraries or other code dependencies must be considered in the same light as the code you author



Secure Your Development Environment

- If your development environment is insecure, it's difficult to have confidence in the security of the code it produces
- These environments need to be suitably secure but should also facilitate and not impede the development process
- It is possible to provide a solution that is both secure and usable by developers



Protect Your Code Repository

- As a central point from which your code is stored and managed, it's crucial that the repository is sufficiently secured
- Loss or compromise of access credentials or breach of the underlying service may allow attackers to modify your codebase without your knowledge
- However, if proper security measures are taken, the benefits of using a code repository service far outweigh the risks



Secure the Build and Deployment Pipeline

- There are huge efficiency savings to be had from automating functions such as building code, running tests, and deploying reference environments
- These processes are security critical
- Take care to ensure that your build and deployment tooling cannot undermine the integrity of your code, and that key security processes cannot be bypassed before changes are pushed to your customers



Continually Test Your Security

- Performing security testing is critical to detecting and fixing security vulnerabilities
- However, it should not get in the way of continuous delivery. Where possible, automating security testing provides repeatable, scalable security measures, while allowing your security specialists to concentrate on finding subtle and uncommon weaknesses



Plan for Security Flaws

- All code is susceptible to bugs and security vulnerabilities
- Accept that your code will have exploitable shortcomings and establish a process for capturing and managing them from identification through to the release of a fix
- Keep track of your **security debt** by tracking issues with a register, from identification to mitigation



Defence-in-Depth Principle

- A security strategy involving multiple layers of security controls to protect an organization's assets
- Based on the idea that if one layer fails, the others can still protect the asset
- Layers can include:
 - physical security
 - network security
 - application security
 - data security
- The goal is to create a secure environment that is resilient to attack and can quickly detect and respond to any security incidents
- By implementing multiple layers of security, organizations can reduce the risk of a successful attack and minimize the damage caused by any successful attack



Zero Trust Principle

- A security model that assumes that all users, devices, and networks are untrusted and must be verified before access is granted, even if they are inside the organization's network
- Requires organizations to continuously monitor and audit user activity to ensure that access is only granted to those who need it
- Designed to reduce the risk of data breaches and other security incidents by ensuring that only authorized users have access to sensitive data



Security-in-the-Open Principle

- A concept that emphasizes the importance of security in open-source software development
- Focuses on the need for developers to be aware of the security implications of their code and to take steps to ensure that their code is secure
- This includes:
 - secure coding practices
 - testing for vulnerabilities
 - secure development tools
- Encourages developers to collaborate with security experts to ensure that their code is secure



National Cyber Security Strategy for Businesses (1 of 2)

- Develop an incident response plan
- Keep Operating Systems and Applications up to date
- Enable Security Software
- Securely Configure Devices
- Use Strong User Authentication
- Provide Employee Awareness Training
- Back up and Encrypt Data



National Cyber Security Strategy for Businesses (2 of 2)

- Secure Mobile Devices
- Implement Firewalls, VPNs and other Perimeter Defences
- Secure Cloud and Outsourced IT Services
- Secure Websites
- Implement Access Control and Authorization
- Secure Portable Media



Managing for Success

- **Business Issues**
 - Every system is to provide a solution to a business problem or opportunity. If a system does not do this, it is a failure
- **Budget Issues**
 - Unrealistic estimates that are too optimistic or based on incomplete information
 - Failure to develop an accurate forecast that considers all costs over the life of the project
 - Poor monitoring of progress and slow response to early warning signs of problems
 - Schedule delays due to factors that were not foreseen
 - Human resource issues, including turnover, inadequate training, and motivation



Managing for Success (Cont.)

- **Schedule Issues**
 - Problems with timetables and project milestones can indicate a failure to recognize task dependencies, confusion between effort and progress, poor monitoring and control methods, personality conflicts among team members, or turnover of project personnel
 - The failure of an IT project also can be caused by poor project management techniques



The Bottom Line

- Project managers must be alert, technically competent, and highly resourceful. They also must be good communicators with strong human resource skills
- When problems occur, the project manager's ability to handle the situation becomes the critical factor



References

- **E-Commerce 2023: Business, Technology, Society, 17th edition**
 - **Kenneth C. Laudon**

- **Business Essentials, 14th edition**
 - **Ronald J. Ebert**

